Módulo 10: Segurança da Informação (resumo teórico)

Resumo teórico em português para estudo. Cobre o escopo do módulo 10 do edital do TCE-GO (Técnico de Controle Externo, TI): princípios da segurança da informação (confidencialidade, integridade, disponibilidade, autenticidade e não repúdio); gestão de riscos, de vulnerabilidades e de incidentes; classificação da informação; controle de acesso (autenticação, autorização e gestão de identidades, IAM); criptografia simétrica e assimétrica, infraestrutura de chaves públicas, certificados e assinatura digital; segurança em aplicações (OWASP Top 10:2025, codificação segura e DevSecOps, APIs, contêineres e nuvem); backup, continuidade de negócios e recuperação de desastres; malware, ransomware, phishing e engenharia social; firewalls, antivírus, IDS/IPS, testes de invasão e análise de vulnerabilidades; Zero Trust; e a família de normas ABNT NBR ISO/IEC 27000. Os números citados vêm de laboratórios executados de verdade (L1 a L10), em Python, OpenSSL e Node.js, na máquina de trabalho, sem alterar configurações do sistema. O que não foi executado está marcado como "não testado" (nuvem real, contêineres endurecidos, firewalls e IDS comerciais, ferramentas de pentest, módulos de segurança em hardware e o texto das normas ISO, que são pagas). As questões reais de treino são da FCC (Técnico e Analista Judiciário de TI e a prova do próprio TCE-GO de 2009), sempre com a fonte, e são completadas por questões autorais marcadas como tal.

1. Princípios da segurança da informação e classificação da informação

- Tripé CIA: **confidencialidade** (só quem está autorizado acessa), **integridade** (a informação não é alterada indevidamente e se mantém conforme o original) e **disponibilidade** (acessível quando necessária, por quem tem direito). O edital soma **autenticidade** (garantia da origem e da identidade) e **não repúdio** (o autor não pode negar a autoria; exige chave privada e assinatura digital, ou registros confiáveis).
- Pegadinhas de prova: a FCC descreve o princípio por uma situação ("garante que está conforme o conteúdo original" é integridade; "pode acessar sempre que quiser, se autorizado" é disponibilidade; "somente um grupo autorizado" é confidencialidade). "Autoridade" e "publicidade" não são princípios do tripé.
- Cada tecnologia protege um princípio: criptografia, controle de acesso e classificação protegem a confidencialidade; hash, assinatura e controle de versão protegem a integridade; backup, redundância e contingência protegem a disponibilidade; certificados e MFA reforçam a autenticidade; assinatura digital com chave privada dá o não repúdio. No laboratório L3, o AES-GCM mostrou dois princípios com um só mecanismo: cifrar (confidencialidade) e a etiqueta de autenticação de 16 bytes (integridade).
- Classificação da informação: rotular a informação (por exemplo pública, interna, confidencial e secreta) conforme valor, sensibilidade e exigências legais, para decidir quem acessa, como é armazenada, transmitida e descartada. É a base do controle de acesso e da criptografia proporcional. No setor público, a Lei de Acesso à Informação

(Lei 12.527/2011) classifica informação sigilosa em reservada, secreta e ultrassecreta, e a LGPD (Lei 13.709/2018, art. 46) exige medidas de segurança para dados pessoais.
- Defesa em profundidade: várias camadas de controles (físico, lógico, administrativo), de modo que a falha de uma não comprometa tudo. Segregação de funções: ninguém deve concentrar todas as etapas de uma operação crítica.

2. Gestão de riscos, de vulnerabilidades e de incidentes

- Conceitos: **ativo** (o que tem valor), **ameaça** (causa potencial de dano), **vulnerabilidade** (fraqueza explorável), **risco** (probabilidade de a ameaça explorar a vulnerabilidade, combinada com o impacto) e **incidente** (evento que de fato compromete a segurança). Um **evento** é qualquer ocorrência observável; só vira incidente se tiver impacto.
- Processo de gestão de riscos (ISO/IEC 27005 e ISO 31000): estabelecer o contexto, identificar, analisar, avaliar, tratar, monitorar e comunicar. A análise pode ser **qualitativa** (alto, médio, baixo) ou **quantitativa**.
- Análise quantitativa: **SLE** = AV × EF (perda por ocorrência: valor do ativo × fator de exposição); **ALE** = SLE × ARO (perda anual esperada: taxa anual de ocorrência). No laboratório L9, o servidor de processos (R$ 500.000, EF 40%, ARO 0,5) deu ALE de R$ 100.000; a base de pessoal, R$ 40.000; a estação de usuário, R$ 18.000; total R$ 158.000. Um controle de R$ 40.000 por ano que reduziu o ARO do servidor de 0,5 para 0,1 economizou R$ 80.000 de ALE e valeu a pena.
- Tratamento do risco: **mitigar** (reduzir probabilidade ou impacto), **transferir** (seguro, terceirização), **evitar** (abandonar a atividade) e **aceitar** (de forma consciente, dentro do apetite de risco). O que sobra depois do tratamento é o **risco residual**.
- Gestão de vulnerabilidades: ciclo contínuo de descobrir (varreduras e inventário), priorizar (gravidade, exposição, explorabilidade), corrigir (patches, configuração) e verificar. **CVE** identifica uma vulnerabilidade pública; **CWE** classifica o tipo de fraqueza; **CVSS** dá a gravidade de 0 a 10 (9,0 a 10,0 é crítica); o **NVD** é a base do NIST. Análise de vulnerabilidades **lista** falhas; o teste de invasão (seção 10) tenta **explorá-las**.
- Gestão de incidentes (ISO/IEC 27035 e NIST SP 800-61): **preparação**; **detecção e análise** (relato, triagem, classificação); **contenção, erradicação e recuperação**; **lições aprendidas**. Na 27035 existe o **Ponto de Contato (PoC)**, que recebe o relato de eventos, e a **equipe de resposta a incidentes (IRT/CSIRT)**, que trata o incidente depois de avaliado. A detecção usa IDS/IPS, antivírus e EDR, e análise de logs com SIEM; uma ferramenta de exploração como o Metasploit não é de detecção (questão do TRT-4 2022). No laboratório L9, uma regra de limiar (10 falhas de login em 60 s) gerou o alerta contra o IP que fez 30 tentativas, que é a lógica de detecção que um SIEM ou IDS aplica em escala.
- Referências de gestão: NIST Cybersecurity Framework 2.0 (funções Governar, Identificar, Proteger, Detectar, Responder e Recuperar) e CIS Controls v8 (18 controles, com ênfase em inventário, gestão de logs e defesa de rede). O SIEM correlaciona logs de várias fontes, e o CIS v8 recomenda centralizar os alertas de eventos para correlação e análise (questão do TRT-22 2022).

3. Controle de acesso, autenticação, autorização e IAM

- **Identificação** (quem diz ser), **autenticação** (prova disso), **autorização** (o que pode fazer) e **auditoria ou contabilização** (registro do que fez), o chamado AAA. **IAM** (Identity and Access Management) cuida do ciclo de vida das identidades (criar, alterar, revogar), das credenciais, dos papéis e das políticas de acesso.
- Fatores de autenticação: **conhecimento** (senha, PIN), **posse** (token, celular com TOTP, cartão) e **inerência** (biometria). **MFA** exige fatores de **tipos diferentes**; senha mais pergunta secreta são dois fatores do mesmo tipo.
- Senhas: o que importa é o comprimento e a imprevisibilidade. A entropia vale comprimento × $\log_2$(alfabeto): no L2, 8 minúsculas dão 37,6 bits, 8 letras e dígitos 47,6, 8 símbolos de 94 caracteres 52,4, 12 de 94 78,7, e 4 palavras sorteadas de uma lista de 7776 (diceware) 51,7 bits. Só vale para escolha aleatória. A orientação do NIST SP 800-63B é priorizar o comprimento, verificar a senha contra listas de senhas vazadas, não exigir regras de composição nem troca periódica sem indício de comprometimento, e limitar tentativas.
- Armazenamento de senhas: nunca em claro nem com cifra reversível; use **hash lento com sal único** (PBKDF2, scrypt, bcrypt ou Argon2). No L2, sem sal duas contas com a senha "123456" tiveram o mesmo SHA-256 e um dicionário recuperou "senha123"; com sal, os hashes ficaram diferentes. O SHA-256 puro fez milhões de tentativas por segundo e o PBKDF2 com 600.000 iterações cerca de 10 (taxas de uma CPU, medidas nesta execução, variam). Para 8 minúsculas, a força bruta média foi de horas no SHA-256 puro e de centenas de anos no PBKDF2 de 600.000 iterações; GPUs e hardware dedicado são muito mais rápidos.
- Modelos de controle de acesso: **DAC** (o dono define), **MAC** (rótulos de sensibilidade definidos pelo sistema), **RBAC** (por papéis) e **ABAC** (por atributos do usuário, do recurso e do contexto, como horário e local). Princípios: **menor privilégio** e **necessidade de conhecer**. No L7, as mesmas decisões foram tomadas por papéis e por atributos: um usuário de nível 3 foi negado às 22 h por regra de horário.
- **Autenticação por tokens**: HOTP (RFC 4226, contador) e TOTP (RFC 6238, tempo, janelas de 30 s) aplicam HMAC sobre um segredo compartilhado; no L7, os vetores oficiais das duas RFCs foram reproduzidos (HOTP 755224, 287082, 359152, 969429, 338314; TOTP 94287082, 07081804, 89005924). Limitar tentativas é essencial: um código de 6 dígitos tem 10^6 possibilidades, 27,8 h a 10 tentativas por segundo, mas com bloqueio após 5 erros a chance é 5×10^-6.
- **OAuth 2.0** (RFC 6749) é autorização delegada, com quatro papéis: Resource Owner (dono do dado), Client (aplicação), Authorization Server (emite o token) e Resource Server (guarda o recurso). **OpenID Connect** acrescenta a identidade sobre o OAuth. **SAML** é o padrão corporativo de federação e SSO por asserções XML; **Kerberos** autentica com tickets em redes de domínio. **JWT** (RFC 7519) tem cabeçalho, payload e assinatura em Base64url: o payload é **legível por todos**; a assinatura (HMAC com segredo, ou RSA e ECDSA com par de chaves) só impede a alteração. No L7, alterar o payload invalidou a assinatura, e um verificador que aceita `alg: none` aceitou o token forjado como administrador, enquanto o verificador estrito o recusou.
- Em nuvem, o IAM define políticas (quem pode fazer o quê em qual recurso), papéis temporários e MFA para contas privilegiadas. Contas de serviço e chaves de acesso são alvos frequentes; use menor privilégio e rotação. Não testado: IAM de um provedor de nuvem real.

4. Criptografia simétrica e assimétrica, hash e modos de operação

- **Simétrica**: uma só chave cifra e decifra (AES, 3DES, DES, RC4, ChaCha20). É rápida e boa para grandes volumes; o desafio é distribuir a chave, e para n pessoas trocarem segredos aos pares são necessárias n(n−1)/2 chaves (50 pessoas, 1225). **AES**: bloco de 128 bits, chaves de 128, 192 ou 256 bits (FIPS 197). DES tem chave efetiva de 56 bits (hoje quebrável por força bruta) e bloco de 64 bits.
- **Assimétrica**: par de chaves, pública e privada (RSA, ECC, Diffie-Hellman, ElGamal, DSA). É mais lenta, resolve a distribuição de chaves e permite assinatura; para n pessoas, 2n chaves (50 pessoas, 100). **RSA** se baseia na dificuldade de fatorar o produto de dois primos grandes; o módulo de 1024 bits é considerado fraco, e hoje se usam 2048 bits ou mais (a FCC cobra que a chave RSA "pode superar 1024 bits"). No L4, foram geradas chaves RSA de 1024, 2048 e 3072 bits com expoente público 65537, e o RSA-OAEP com SHA-256 numa chave de 2048 bits aceitou no máximo 190 bytes por operação (uma mensagem de 300 bytes falhou). **ECC** dá segurança equivalente com chaves menores (por exemplo, a curva P-256 ou a Ed25519, com chave pública de 32 bytes e assinatura de 64 bytes, vistas no L4).
- **Cifra híbrida (envelope)**: a assimétrica protege uma chave de sessão simétrica, e a simétrica cifra os dados. É como o TLS funciona. No L4, 1.000.000 de bytes foram cifrados com AES-GCM e a chave de 32 bytes foi embrulhada pelo RSA em 256 bytes. **Acordo de chaves** (Diffie-Hellman, ECDH): as duas partes chegam ao mesmo segredo sem transmiti-lo; o L4 mostrou o X25519 e a derivação com HKDF de uma chave de 256 bits.
- **Modos de operação**: o **ECB** revela padrões (no L3, 7 blocos repetidos na entrada geraram 7 blocos cifrados repetidos; no CBC e no GCM, 0). **CBC** encadeia blocos com IV e não autentica. **CTR** e **GCM** são modos de fluxo; o **GCM** é um modo **autenticado (AEAD)**: no L3, alterar 1 bit do cifrado e usar um dado associado diferente resultaram em InvalidTag. O **nonce não pode se repetir** com a mesma chave: no L3, com nonce repetido, c1 ⊕ c2 = p1 ⊕ p2 e a segunda mensagem foi recuperada a partir da primeira. Na linha de comando, `openssl enc -aes-256-cbc -pbkdf2` cifrou e decifrou, e uma senha errada deu "bad decrypt".
- **Hash** (resumo criptográfico): função de mão única, de tamanho fixo, determinística e com efeito avalanche. MD5 128 bits (32 dígitos hexadecimais) e SHA-1 160 bits (40 hex) estão **quebrados para colisões**; SHA-256 tem 256 bits (64 hex), SHA-512 512 bits (128 hex); SHA-3 (FIPS 202) é a família Keccak. No L1, uma entrada de 8 e outra de 1600 caracteres geraram digests do mesmo tamanho em cada algoritmo; trocar 1 bit mudou 135 dos 256 bits do SHA-256 (52,7%). **Hash não é criptografia** (não se reverte) e **não autentica**: quem altera a mensagem recalcula o hash. O **HMAC** mistura uma chave e só quem a conhece gera a etiqueta correta (no L1, a etiqueta do atacante foi rejeitada). Hash serve para integridade de arquivos (no L1, `sha256sum`, `openssl dgst` e Python deram o mesmo valor) e para senhas (com sal, seção 3).
- Resumo das propriedades: confidencialidade vem de cifrar; integridade, de hash ou etiqueta; autenticidade e não repúdio, de assinatura com chave privada. Uma questão da FCC (TRT-4 2022): se o hash do documento recebido difere do original, o documento **perdeu a integridade**.

5. PKI, certificados digitais, assinatura digital e TLS

- **Assinatura digital**: calcula-se o hash do documento e cifra-se esse hash com a **chave privada do signatário**; qualquer um verifica com a **chave pública** dele. Garante integridade, autenticidade e não repúdio, mas **não confidencialidade**. No L4, a assinatura RSA-PSS tem 256 bytes numa chave de 2048 bits, e o documento alterado em 1 byte e a verificação com a chave pública de outra pessoa foram ambos inválidos. Para sigilo, cifra-se com a chave **pública do destinatário**.
- **PKI** (infraestrutura de chaves públicas): autoridades certificadoras (AC), autoridades de registro (AR), repositório de certificados e mecanismos de revogação. A **cadeia de confiança** vai do certificado final, passando por ACs intermediárias, até a **AC raiz**, que é autoassinada e já vem instalada nos sistemas. No Brasil, a **ICP-Brasil** foi instituída pela Medida Provisória 2.200-2/2001, tem o ITI como AC raiz, e a Lei 14.063/2020 distingue assinatura eletrônica simples, avançada e qualificada (esta usa certificado ICP-Brasil).
- **Certificado digital X.509** (RFC 5280): titular (subject), emissor (issuer), número de série, validade (notBefore e notAfter), chave pública, extensões (SAN, uso da chave, restrições básicas, como CA:TRUE ou CA:FALSE) e a assinatura da AC. Na ICP-Brasil, o tipo **A1** é gerado e guardado em **software**, vale **1 ano** e pode ser copiado; o **A3** fica em cartão ou token (hardware) e não se copia. O cadeado do navegador mostra o certificado do site, nunca a chave privada.
- No L5, com OpenSSL (tudo em um diretório temporário, apagado ao final): foi criada uma AC autoassinada (CA:TRUE, Certificate Sign e CRL Sign), um certificado de servidor com SAN DNS:localhost e IP:127.0.0.1, CA:FALSE, uso Server Authentication e validade de 90 dias. A verificação com a AC deu OK; sem a AC, "unable to get local issuer certificate" (erro 20); numa data 200 dias depois, "certificate has expired" (erro 10); trocar uma letra do nome (localhost para mocalhost) quebrou a assinatura ("certificate signature failure", erro 7).
- **Revogação**: a **CRL** (lista de certificados revogados, assinada pela AC) e o **OCSP** (consulta online do status, RFC 6960) informam que um certificado deixou de valer antes do prazo, por exemplo por comprometimento da chave. No L5, o certificado de série 1000 foi revogado por keyCompromise e a verificação com `-crl_check` deu "certificate revoked" (erro 23), e o certificado não revogado seguiu OK.
- **TLS** (RFC 8446 para o 1.3; o 1.2 é a RFC 5246): fica acima do TCP, entre o transporte e a aplicação. Tem os **protocolos de handshake** (negociam versão e cifras, autenticam o servidor, e opcionalmente o cliente, por certificado, e acordam as chaves) e o **Protocolo de Registro** (fragmenta, comprime em versões antigas, protege e transmite os dados). O cliente valida a cadeia, a validade, a revogação e se o **nome acessado está no SAN**. Fortezza e o alerta "no certificate" são do SSL 3.0 (questão do TRT-14 2022). No L5, em 127.0.0.1, o handshake negociou **TLSv1.3** com TLS_AES_256_GCM_SHA384; sem a AC, falhou com "unable to get local issuer certificate" (código 20); com a AC e o nome errado, falhou com "Hostname mismatch" (código 62).
- Não testado: módulos de segurança em hardware (HSM), uma AC da ICP-Brasil real, OCSP stapling e emissão de certificado por serviço público (como o ACME).

6. Segurança em aplicações: OWASP Top 10:2025

O OWASP Top 10:2025 (a 8ª edição) tem as seguintes categorias:

- **A01 Broken Access Control**: o usuário faz o que não deveria (alterar o ID na URL, travessia de diretório, falta de verificação no servidor). Continua em 1º lugar; o SSRF foi incorporado a ela em 2025.
- **A02 Security Misconfiguration**: configuração padrão, serviços desnecessários, mensagens de erro detalhadas, permissões abertas. Subiu do 5º para o 2º lugar.
- **A03 Software Supply Chain Failures**: comprometimento de dependências, sistemas de build e infraestrutura de distribuição; amplia a antiga "Componentes Vulneráveis e Desatualizados". Defesas: SBOM, fixar versões, verificar assinaturas e integridade, revisar dependências.
- **A04 Cryptographic Failures**: dados sensíveis sem cifra adequada, algoritmos fracos, chaves mal geridas.
- **A05 Injection**: SQL, comandos de sistema, XSS e outras injeções; a entrada do usuário é tratada como código.
- **A06 Insecure Design**: falhas de projeto, sem modelagem de ameaças e sem requisitos de segurança.
- **A07 Authentication Failures**: senhas fracas, sem limite de tentativas, sem MFA, sessões mal geridas.
- **A08 Software or Data Integrity Failures**: falta de verificação de integridade de código e dados (atualizações sem assinatura, desserialização insegura).
- **A09 Security Logging and Alerting Failures**: sem registro e sem alerta, ataques passam despercebidos. O nome mudou para destacar o alerta.
- **A10 Mishandling of Exceptional Conditions**: categoria nova; tratamento inadequado de erros e condições anormais, lógica que falha aberta.
- Testes no L6 (Python, banco SQLite na memória): a entrada `' OR '1'='1` devolveu os dois usuários na consulta concatenada, e `admin'--` entrou como admin; a consulta **parametrizada** negou ambos. Um `UNION` exfiltrou as senhas por um campo de busca, e a versão segura devolveu lista vazia. No XSS, `html.escape` transformou o `<script>` em texto inerte. A travessia `../segredo.txt` leu um arquivo fora do diretório na versão vulnerável e foi barrada (PermissionError) na segura. Na injeção de comandos, `shell=True` executou o comando injetado, e a lista de argumentos não.
- Defesas gerais: validar a entrada (lista de permissões) e **codificar a saída** conforme o contexto, consultas parametrizadas, menor privilégio, política de segurança de conteúdo (CSP), cookies com HttpOnly, Secure e SameSite, proteção contra CSRF, atualização de dependências e segredos fora do código. Um **WAF** (Web Application Firewall) filtra HTTP na camada 7, mas não substitui o código seguro.

7. Codificação segura, DevSecOps, APIs, contêineres e nuvem

- **Desenvolvimento seguro**: segurança desde o requisito (shift left), modelagem de ameaças, revisão de código, testes e resposta a vulnerabilidades. O **NIST SSDF** (SP 800-218) organiza as práticas em quatro grupos: **PO** (Preparar a Organização), **PS** (Proteger o Software), **PW** (Produzir Software Bem Protegido) e **RV** (Responder a Vulnerabilidades). Outras referências: OWASP ASVS e SAMM.

- **DevSecOps** leva a segurança para o pipeline de CI/CD: **SAST** (análise estática do código), **SCA** (dependências e licenças), varredura de segredos, análise de imagens, **DAST** (teste da aplicação em execução), **IAST** (instrumentação), testes de IaC, e bloqueio do merge ou do deploy quando um critério falha. Assinatura de artefatos e **SBOM** respondem à cadeia de suprimentos (A03).
- **APIs**: o OWASP API Security Top 10 (edição 2023) destaca a autorização quebrada em nível de objeto (BOLA, o equivalente do IDOR), a autenticação quebrada, o consumo irrestrito de recursos e a autorização quebrada em nível de função. Boas práticas: autenticar e autorizar cada chamada (OAuth 2.0 e JWT validados de forma estrita), limitar taxa, validar o esquema da entrada, retornar o mínimo de dados e registrar o acesso.
- **Contêineres**: os contêineres compartilham o núcleo do hospedeiro e se isolam por namespaces e cgroups; não são máquinas virtuais. Endurecimento: imagem mínima de origem confiável, varredura de vulnerabilidades, **usuário sem privilégio** (não root), sistema de arquivos somente leitura, remover capacidades, **sem segredos na imagem**, nunca usar o modo privilegiado nem montar o socket do Docker, e fixar a versão da imagem em vez de usar a tag `latest`. No Kubernetes: RBAC, Pod Security Standards (privileged, baseline e restricted), políticas de rede, e gestão de segredos. Não testado neste módulo: a execução e o endurecimento real de contêineres e clusters.
- **Nuvem**: o modelo de **responsabilidade compartilhada**. Em IaaS, o provedor cuida da infraestrutura física e do virtualizador, e o cliente cuida do sistema operacional convidado, das regras de rede, das identidades e dos dados; em PaaS e SaaS, o provedor assume mais camadas, mas dados e identidades continuam do cliente. Riscos típicos: armazenamento aberto ao público, credenciais expostas, permissões excessivas e falta de registro. Controles: IAM com menor privilégio, MFA, cifra em repouso e em trânsito com gestão de chaves (KMS), registro e monitoramento, e postura (CSPM). Não testado: serviços de nuvem reais.

8. Backup, continuidade de negócios e recuperação de desastres

- **Tipos de backup**: **completo** (copia tudo), **incremental** (o que mudou desde a última cópia de qualquer tipo; menor e mais rápido, mas restaura com a cadeia inteira) e **diferencial** (o que mudou desde o último completo; maior, mas restaura com apenas 2 conjuntos). No L8 (arquivos de teste em diretório temporário): no dia 3, o incremental guardou 2 arquivos e o diferencial 5; restaurar com o completo e os três incrementais usou 4 conjuntos e ficou idêntico ao original; completo mais o último diferencial usou 2 conjuntos e também ficou idêntico; sem o elo do dia 2, a restauração **não** ficou idêntica. Corromper 1 byte do backup fez o hash deixar de conferir com o manifesto: **testar a restauração e verificar o hash** faz parte do backup.
- **Regra 3-2-1**: 3 cópias, em 2 tipos de mídia, com 1 fora do local (idealmente isolada ou imutável). No L8, um HD externo sozinho e 3 cópias no mesmo NAS reprovaram; original, NAS e nuvem passou. A cópia isolada ou imutável é a principal defesa contra o **ransomware**, que procura cifrar também as cópias acessíveis.

- **BIA** (análise de impacto no negócio) define o impacto da parada de cada processo e as metas: **RTO** (tempo máximo aceitável para restaurar o serviço), **RPO** (quantidade máxima de dados que se admite perder, medida em tempo; define a frequência do backup) e o tempo máximo tolerável de parada (MTPD). No L8, backup a cada 24, 4 e 1 hora dá RPO máximo de 24, 4 e 1 hora. O RTO vem da BIA e não foi medido nos laboratórios.
- **Plano de continuidade de negócios (PCN)**, **plano de recuperação de desastres (PRD)** e **plano de contingência** são níveis diferentes: o PCN mantém os processos críticos funcionando; o PRD restaura a TI; o plano de contingência trata de cenários específicos. A **ISO 22301** (no Brasil, ABNT NBR ISO 22301:2020) define o **Sistema de Gestão de Continuidade de Negócios (SGCN)** e adota o ciclo **PDCA**. Cada plano de continuidade traz propósito e escopo, papéis, ações, informações de ativação e comunicação, interdependências, requisitos de relatórios, processo de evacuação e **recursos necessários**.
- **Sítios alternativos**: *hot* (pronto, replicando, RTO curto), *warm* (parcialmente pronto) e *cold* (só espaço e energia, RTO longo). Quanto menor o RTO e o RPO, maior o custo.
- **Disponibilidade**: tempo de parada por ano = (1 − disponibilidade) × 8760 h: 99% são 87,6 h, 99,9% são 8,76 h, 99,99% são 0,876 h. Em série as disponibilidades se multiplicam (99% × 99% = 98,01%); em paralelo (redundância), 1 − (1 − a)(1 − b) (99,99%). Conferido em Python e em JavaScript no L10.

9. Malware, ransomware, phishing e engenharia social

- **Vírus**: precisa de um hospedeiro e da ação do usuário. **Worm**: se replica sozinho pela rede, sem hospedeiro, e congestiona redes (questão do TCE-GO 2009). **Trojan (cavalo de Troia)**: parece legítimo e abre uma porta para o invasor. **Ransomware**: cifra ou bloqueia os dados e exige resgate (muitas vezes em criptomoeda), e a defesa principal é o backup isolado e testado. **Spyware** espiona; **keylogger** captura teclas; **screenlogger** captura telas; **adware** exibe propaganda; **backdoor** é a porta dos fundos; **rootkit** esconde a presença do invasor; **botnet** é a rede de máquinas comandadas à distância; **bot** é o programa instalado em cada máquina.
- **Phishing**: mensagem falsa para obter credenciais ou dados; variantes: *spear phishing* (direcionado), *whaling* (alvo executivo), *vishing* (voz), *smishing* (SMS), *pharming* (redirecionamento por DNS), e a fraude do falso executivo (BEC). A defesa é conferir por um **canal independente**, desconfiar de urgência, de autoridade e de sigilo, e usar MFA, que reduz o dano de credenciais roubadas.
- **Engenharia social**: explora o fator humano: pretexting (pretexto), baiting (isca), tailgating (entrar atrás de alguém) e persuasão para obter senhas. Defesas: conscientização e treinamento, processos de verificação e simulações de phishing.
- Outros ataques: **spoofing** (falsificação de IP, DNS ou e-mail; questão do TRT-14 2022), **man-in-the-middle** (interceptação entre duas partes; o TLS com validação de certificado é a defesa), **DoS e DDoS** (negação de serviço) e **SYN flood**: muitos SYN sem o ACK final deixam conexões semiabertas e esgotam a tabela de conexões (questão do TRT-22 2022); mitigação com SYN cookies, limites por origem, firewall com estado e serviços anti-DDoS. Ataques de reflexão e amplificação usam servidores

intermediários (como DNS) para multiplicar o tráfego. Ataques de dia zero exploram falha ainda sem correção.

10. Firewalls, antivírus, IDS/IPS, testes de invasão e análise de vulnerabilidades

- **Firewall**: separa zonas de confiança e aplica política, com a boa prática de **negar por padrão** (*default deny*). **Filtro de pacotes** (sem estado) decide por cabeçalhos: IPs, portas e protocolo (por isso consegue bloquear um IP de origem não autorizado, mas não lê o conteúdo de e-mails nem de sites). **Stateful inspection** guarda a tabela de conexões e avalia o pacote no contexto do estado. **Proxy de aplicação** intermedeia a conexão na camada de aplicação. **NGFW** (próxima geração) soma inspeção de aplicação, prevenção de intrusão e identidade. **WAF** protege aplicações web. Zona desmilitarizada (**DMZ**) isola os serviços expostos. No L9 (simulado em Python): a regra "permitir 443 de qualquer lugar e 22 só da rede 10.0.0.0/8" liberou e negou como esperado, e dois ACK soltos na porta 443 passaram no filtro sem estado, mas o filtro com estado só aceitou o ACK da conexão registrada pelo SYN.
- **Antivírus** (assinaturas, heurística e comportamento) protege o terminal; **EDR** monitora e responde em estações e servidores; **XDR** amplia a correlação para vários vetores; **SIEM** centraliza e correlaciona logs; **SOAR** automatiza a resposta.
- **IDS** detecta e alerta (passivo) e o **IPS** fica no caminho do tráfego (*inline*) e **bloqueia**. Detecção por **assinatura** (padrões conhecidos) ou por **anomalia** (desvio do comportamento normal). **NIDS/NIPS** monitoram um segmento de rede, com sensores e uma estação de gerenciamento, e têm dificuldade com tráfego cifrado e com redes saturadas (questão do TRT-22 2022); **HIDS/HIPS** rodam em um host. Não testado: Snort, Suricata e firewalls comerciais; o L9 só simulou a lógica.
- **Teste de invasão (pentest)**: simulação autorizada de ataque, com escopo e regras de engajamento. Por conhecimento do alvo: **white box** (pleno conhecimento e código-fonte), **gray box** (parcial) e **black box** (pouco ou nenhum, como um invasor externo). Também há testes de engenharia social, **físicos** (fechaduras, barreiras, câmeras) e de aplicações web ou redes sem fio (questão do TRT-23 2022). Etapas: reconhecimento, varredura e enumeração, exploração, pós-exploração e relatório. No L9, uma varredura de portas **somente em 127.0.0.1**, nas portas que o próprio script abriu, achou as 3 portas abertas por conexão TCP completa; não foram usadas ferramentas externas como o nmap, e nenhuma outra máquina foi testada.

11. Zero Trust e a família ABNT NBR ISO/IEC 27000

- **Zero Trust** (NIST SP 800-207): "nunca confie, sempre verifique". Não há confiança implícita por localização de rede (estar na rede corporativa ou na VPN não basta). Cada acesso é autenticado e autorizado de forma dinâmica, com base na **identidade**, no **estado do dispositivo** e no **contexto**, com **menor privilégio**, microssegmentação, monitoramento contínuo e a premissa de que a rede já pode estar comprometida. Componentes lógicos: motor de políticas (Policy Engine), administrador de políticas (Policy Administrator) e ponto de aplicação (Policy Enforcement Point). **ZTNA** é o acesso à rede por esse modelo. O NAC (controle de admissão de rede) verifica o

dispositivo antes (pré-admissão) ou depois (pós-admissão) de liberar o acesso; a FCC (TRT-23 2022) pergunta sobre o NAC com base no modelo Zero Trust, que nega o acesso por padrão e impõe políticas de identidade e de contexto.
- **Família ISO/IEC 27000**: **27000** (visão geral e vocabulário); **27001** (requisitos do **SGSI**, o sistema de gestão da segurança da informação; é a norma **certificável**; segue o ciclo PDCA e tem anexo de controles); **27002** (código de prática com os controles; a versão de 2022 tem 93 controles em 4 temas: organizacionais, de pessoas, físicos e tecnológicos; a de 2013 tinha 114 controles em 14 domínios); **27005** (gestão de riscos); **27035** (gestão de incidentes, em partes); **27701** (privacidade); **27017 e 27018** (nuvem). A ISO 22301 é de continuidade, fora da família 27000.
- A **Política de Segurança da Informação** é o documento de mais alto nível: traz o comprometimento da direção, a estrutura para os objetivos de controle e a análise de riscos, e as responsabilidades, inclusive o registro de incidentes (questão do TRT-2 2014). A 27001 e a 27002 pedem, entre os controles de equipamentos, a **manutenção correta** para assegurar integridade e disponibilidade, a **autorização** para retirar equipamentos, a verificação e o apagamento de mídias antes da reutilização e a **separação** de cabos de energia e de telecomunicações (questão do TRT-4 2022).
- Observação: o texto das normas ISO é pago e não foi lido aqui; este resumo se baseia em fontes públicas e nas provas da FCC. Confira sempre a versão (2005, 2013 ou 2022) pedida no enunciado.

12. Resumo para a prova

- CIA e mais autenticidade e não repúdio; a FCC descreve o princípio por uma situação. Hash não é criptografia e não autentica; HMAC e assinatura autenticam.
- Tamanhos: MD5 128 bits (32 hex), SHA-1 160 (40), SHA-256 256 (64), SHA-512 512 (128). AES: bloco de 128 bits. RSA: assimétrico, chave que pode superar 1024 bits.
- Simétrica: $n(n-1)/2$ chaves; assimétrica: $2n$. Cifra híbrida em TLS. Assina-se com a **chave privada** e cifra-se com a **pública do destinatário**.
- Certificado A1 (software, 1 ano) e A3 (hardware). Cliente TLS valida cadeia, validade, revogação (CRL e OCSP) e nome (SAN).
- OWASP Top 10:2025: A01 Broken Access Control, A02 Security Misconfiguration, A03 Software Supply Chain Failures, A04 Cryptographic Failures, A05 Injection, A06 Insecure Design, A07 Authentication Failures, A08 Software or Data Integrity Failures, A09 Security Logging and Alerting Failures, A10 Mishandling of Exceptional Conditions. Defesa da injeção: consulta parametrizada.
- DevSecOps: SAST, SCA, DAST; NIST SSDF = PO, PS, PW e RV. Contêiner: não root, sem segredo na imagem, nunca privilegiado.
- Backup: completo, incremental (cadeia inteira), diferencial (2 conjuntos); 3-2-1; RPO é perda de dados, RTO é tempo de volta; ISO 22301 usa PDCA.
- Malware: worm replica sozinho, trojan se disfarça, ransomware sequestra, spyware espiona, keylogger captura teclas. SYN flood ataca a disponibilidade.
- Firewall sem estado olha cabeçalhos; com estado guarda conexões; WAF atua na camada 7. IDS detecta, IPS bloqueia. Pentest: white, gray e black box.
- Zero Trust: nunca confie, sempre verifique. ISO 27001 é certificável (SGSI); 27002 traz os controles; 27005, riscos; 27035, incidentes.